

Release Notes — dual-dar-data-partition

Date: June 11, 2026
Base: upstream/develop
Branch: dual-dar-data-partition (shiba-meta-secure-boot)

1. Overview

This release delivers TPM-anchored measured boot and TPM-sealed data-at-rest (DAR) protection for the Akita/Shiba STM32MP15 platform, restructured around a dedicated, operator-managed encrypted `/data` partition.

The boot chain measures each stage into the TPM (ST33KTPM2I, SHA-384). Protection splits into two domains:

- **Unattended system volumes (rootfs + overlay)** — encrypted with a **TPM-key-only** LUKS key (no operator passphrase). The key is released by the TPM in the initramfs only when the device identity and the measured boot state both match the values captured at provisioning. Applies to **both** the grey and red variants.
- **Operator data (/data) — red variant only** — a dedicated, fixed-size 1 GiB partition (`p10` , GPT label `data` , ahead of the elastic overlay) carrying user data under **two independent DAR layers**, provisioned and unlocked **post-boot via SCL**:
 - **Outer FDE** (LUKS2) — operator passphrase $\oplus$ TPM.
 - **Inner FE** (gocryptfs /securefs) — a second secret (PIN2), nested **inside** the FDE volume (dual-DAR).

Variant summary

	grey	red
rootfs / overlay	TPM-key-only, unattended	TPM-key-only, unattended
/data outer FDE	— (no data partition)	operator passphrase $\oplus$ TPM, via SCL
/securefs inner FE	—	PIN2 $\oplus$ TPM (gocryptfs over /data)
operator interaction at boot	none	none — the system boots unattended; /data is unlocked on demand

2. Key Model

Protected volumes use the two-sub-mask XOR KEK from the shared library (`fde-kek-lib.sh`):

```
1 KEK = submask_A XOR submask_B
```

Volume	submask_A	submask_B	Unlocked
rootfs / overlay	— (none; single-factor)	64 random bytes, TPM-sealed per bank	initramfs, automatic
/data outer FDE (red)	PBKDF2-HMAC-SHA384(operator passphrase, salt, 10000) — re-derived each unlock, never stored	64 random bytes, TPM-sealed per bank	security fde mount
/securefs inner FE (red)	PBKDF2-HMAC-SHA384(PIN2, FE salt)	64 random bytes, TPM-sealed per bank (FE-specific salt)	security fe mount

rootfs/overlay use the TPM-sealed submask_B as the key directly (no passphrase factor); /data and /securefs add the operator secret as submask_A , so the TPM alone can never rebuild those keys.

Compound TPM policy protecting every sealed object:

```
1 PolicyNV(device-id NV index) AND PolicyPCR(sha384:1,4,5,8)
```

- The device-id NV index (`0x01500000`) holds a hash of the platform serial — binds the key to this physical device.
- The PolicyPCR term binds the key to the measured boot state (§3).
- Sessions are EK-salted with response-parameter encryption to defend against SPI bus sniffing.

TPM persistent handles (per A/B bank):

Object	Bank 0	Bank 1
rootfs submask_B	0x81020000	0x81020001
overlay submask_B	0x81020010	0x81020011
/data outer submask_B	0x81020020	0x81020021
/securefs FE submask_B	0x81020030	0x81020031

NV indices: device-bind `0x01500000` ; /data pw_retry / KEK-rotation / passphrase-aging counters `0x01500001 – 0x01500015` .

3. Measured Boot — PCR 1/4/5/8 (SHA-384)

PCR	Measured by	Content
1	TF-A	FIP (FIP-A / FIP-B)
4	U-Boot	FIT image — kernel
5	U-Boot	FIT image — DTB
8	U-Boot	FIT image — ramdisk / initramfs

The FIT image hash algorithm is SHA-384 to match the TPM PCR bank. Any unauthorized change to the firmware or kernel image changes the measurements, and the TPM refuses to release the sealed keys.

Hardware prerequisite: the U-Boot SPI5 TPM device-tree node (shiba-yocto-scripts) must be present, or firmware-stage PCR measurements are not taken and unlock fails.

4. shiba-meta-secure-boot — Changes by Area

4.1 Measured boot — TF-A BL2 + U-Boot PCR extend

TF-A measures the FIP into PCR#1; U-Boot measures the kernel FIT image (kernel / DTB / ramdisk) into PCR#4/5/8. The FIT hash is set to SHA-384 (shiba-kernel-fitimage.bbclass).

4.2 TPM sealing infrastructure

pcr-predict-reseal.sh predicts the target-bank PCR values and re-seals every secret under the compound policy; SPI sessions are EK-salted + response-encrypted; clear_tpm.sh purges all persistent handles and NV indices (dedup + corrected persistent section).

4.3 Data partition — outer FDE

Shared KEK library (fde-kek-lib.sh) plus the post-boot backends (fde-data-{provision,mount,status,change-passphrase,luks-erase,reencrypt,kek-rotate,unlock-pw-retry}.sh, fde-enroll-passphrase.sh, fde-read-passphrase.sh). Adds:

- two-factor XOR KEK with `submask_A = PBKDF2(operator passphrase);`
- **KEK rotation** — periodically regenerates `submask_B` and re-seals against current PCRs (`security fde kek-rotation`);
- **passphrase aging** — forces a passphrase change after a configurable number of mounts;
- **FIA_AFL retry lockout** — a TPM monotonic-NV counter locks out repeated wrong-passphrase attempts; the device is never powered off, and the lockout is cleared with `security fde unlock-pw-retry (owner auth)`.

4.4 Inner FE — gocryptfs /securefs

`gocryptfs-fe.sh` creates and mounts an encrypted `/securefs` whose cipherdir lives **inside** the FDE-decrypted `/data` (`/data/.securefs`), giving dual-DAR. Front-end driven (SCLI), keyed by PIN2 ⊕ TPM, with an FE-specific salt independent of the `/data` salt. Red variant only.

4.5 SCLI security fde / security fe command trees

New SCLI subtrees managing the full `/data` and `/securefs` lifecycle (§5), plus supporting changes: device-mode unified onto `shiba-variant`, no idle-logout while a command is running, and `ipset-object` updates routed through a helper (no-op when the firewall is absent).

4.6 Initramfs

Boot logging centralized in `init-common` and routed to `/dev/kmsg` with `INFO:/WARN:/ERROR:` formatting; base-variant stale-TPM-handle clear (`60-tpmclearstale`) on the first boot after a DFU flash.

4.7 Image assembly & flashlayout

Fixed-size `/data` partition placed before the elastic overlay (scales to 32 GB), erase-block-aligned, created empty (PED); `/data` + `/securefs` mount points baked into the rootfs; `gocryptfs-init` and the firewall stack scoped per variant.

4.8 SWUpdate (OTA)

`pcr-predict-reseal.sh --reseal-extras` re-seals every `/data` / `/securefs` secret from the running bank to the target bank under predicted PCRs; cross-variant OTA is refused (base may change variant); a `factory` SWU wipes and re-provisions the `/data` partition.

4.9 VPN PKCS#11 PIN

Restored TPM-sealing of the VPN PKCS#11 token PIN under the device-id + PCR compound policy (fixes PolicyNV 0x126 on factory-red first boot).

5. SCLI Commands

security fde (data partition outer FDE — red)

Command	Description
<code>security fde create-passphrase</code>	Provision <code>/data</code> : luksFormat, seal <code>submask_B</code> , enroll the operator passphrase
<code>security fde mount</code>	Unlock + mount <code>/data</code> (prompts the passphrase)
<code>security fde show status</code>	Device, bank, provisioned/mounted, retries left, KEK-rotation and passphrase-age counters
<code>security fde change-passphrase</code>	Rotate the <code>/data</code> passphrase (re-derives <code>submask_A</code> ; requires the current one)

<code>security fde kek-rotation show status</code>	Show the KEK (submask_B) rotation interval and effective mount count
<code>security fde kek-rotation set interval <2..1000></code>	Set the KEK rotation interval (mounts between rotations)
<code>security fde kek-rotation rotate</code>	Rotate the KEK now
<code>security fde passphrase-rotation show status</code>	Show the passphrase-aging interval and effective mount count
<code>security fde passphrase-rotation set interval <2..10000></code>	Set the passphrase-aging interval (mounts between forced changes)
<code>security fde luks-erase</code>	Destroy keyslots — cryptographic erase, IRREVERSIBLE
<code>security fde luks-reencrypt</code>	Rotate the DEK (master key) of /data
<code>security fde unlock-pw-retry</code>	Clear the FIA_AFL retry lockout (owner auth; audited)

security fe (inner FE /securefs — red)

Command	Description
<code>security fe create-passphrase</code>	Create the /securefs store (PIN2); seal the FE submask_B
<code>security fe change-passphrase</code>	Change PIN2 — re-wrap the gocryptfs master key (submask_B unchanged)
<code>security fe mount</code>	Mount /securefs (prompts PIN2)
<code>security fe unmount</code>	Unmount /securefs
<code>security fe show status</code>	Provisioned / mounted state

6. Provisioning & OTA

⚠ Upgrading from an older release requires a one-time base DFU flash

This release introduces **PCR-predicted re-sealing** (`pcr-predict-reseal.sh`): on OTA it re-seals the FDE/FE keys to the *predicted* post-update measured-boot PCRs (`sha384:1,4,5,8`). Earlier releases' swupdate did **not** have this, so a device running a pre-PCR-predict release **cannot be updated to this firmware by OTA alone** — the old swupdate leaves the keys sealed to the wrong PCRs, they fail to unseal under the new boot measurements, and the device **will not boot**.

To cross over from such a release, do a one-time migration:

1. **DFU-flash the base variant** (STM32CubeProgrammer, USB/DFU) — the device boots with rootfs/overlay **unencrypted** and the TPM **not yet provisioned** with FDE keys (the plaintext initialization state).
2. **OTA-update to grey or red** — this release's swupdate predicts the new PCRs and seals the keys to *this* device.

Once on this release (or newer), OTA works normally and no base re-flash is needed — `pcr-predict-reseal.sh` re-seals the keys across each update.

Boot (both variants): the `initramfs` selects the active A/B bank from `boot_bank`, unseals the rootfs/overlay `submask_B` under the device-id + PCR policy, and unlocks the volumes — unattended, no passphrase.

/data bring-up (red, post-boot via SCL):

1. `security fde create-passphrase` — `luksFormat /data`, generate + seal `submask_B`, enroll the passphrase (provisions the `pw_retry` / rotation / aging NV counters).
2. `security fde mount` — unlock + mount `/data`.
3. `security fe create-passphrase` then `security fe mount` — create + mount the inner `/securefs` (requires `/data` mounted first).

OTA: flash the alternate A/B bank, then `pcr-predict-reseal.sh` re-seals the rootfs key **and** every `/data / /securefs` secret to the target bank's predicted PCRs before reboot. `grey` ↔ `grey` and `red` ↔ `red` are supported; cross-variant OTA is refused. A `factory` SWU clears all TPM handles and secure-erases the `/data` partition, then re-provisioning starts from a clean state.